Mestrado em Ciência da Computação

Detecção de vulnerabilidades com modelos de linguagem

Resultados no PrimeVul e continuidade do mestrado

PPGCC UFMA
Outubro de 2026

Pergunta de pesquisa e recorte atual

Pergunta inicial

Quão pequeno e barato pode ser um modelo mantendo desempenho na detecção de vulnerabilidades?

O que os experimentos permitem examinar agora

1. O desempenho global acompanha a distinção entre uma função vulnerável e sua correção?
2. Como NF4 com adaptador e BF16 mesclado se comparam em qualidade, memória e tempo?

Recorte executado: Qwen2.5-Coder 3B e 7B, PrimeVul e classificação por função.

Anteprojeto do mestrado e manuscrito atual, Introdução e Método. Resultados exploratórios.

Trajetória dos experimentos

Período	Trabalho realizado
Início de setembro	Revisão, protocolo e montagem da bancada.
11–17/set	Primeiros testes por instrução e controle do ambiente.
19–25/set	Migração para a release original e pilotos 3B.
26–29/set	Investigação do comprimento e treino com controle de tamanho.
04–06/out	Três sementes do 7B e avaliações NF4/BF16.
07–08/out	Consolidação, análise dos pares e redação do artigo.

As decisões do piloto conduziram o desenho das rodadas seguintes.

Histórico Git local, notas das etapas 1 e 3 e registros de consolidação de 08/10/2026.

PrimeVul: dados e partições

Funções C/C++ de projetos de código aberto, com rótulos derivados de correções de vulnerabilidades.

Partição	Funções	Vulneráveis	Pares
Treino	184.427	5.574	4.354
Validação	25.430	699	562
Teste	25.911	695	564

- Vulneráveis representam **2,68%** do teste global.
- Uso da **release original**. Rodadas da v0.1 ficaram arquivadas.
- Deduplicação e divisão cronológica reduzem riscos de vazamento.

Ding et al. (2024). Contagens conferidas na release recuperada. Pares são um recorte próprio, não devem ser somados às funções globais.

Avaliação global e avaliação pareada

Global	Pareada
Cada função recebe uma decisão ou um escore.	Comparação entre a função vulnerável e a versão associada à correção.
25.911 funções no teste.	564 pares, com 1.128 registros.
F1, precisão, revocação, FPR e AUC ROC.	Categorias de decisão e ordenação dos escores.

A comparação pareada reduz diferenças de projeto e contexto entre as versões.

Sua interpretação também depende da correspondência correta dos pares.

Ding et al. (2024), Risse e Böhme (2024). Definições locais no Método do manuscrito.

Configurações avaliadas

Configuração	Como produz a resposta	Contexto de entrada
3B/7B Instruct	Prompt sem exemplos, saída YES/NO, FP16	8.192 tokens registrados
3B/7B Base ajustados	LoRA sobre base NF4 e cabeça de duas classes	2.048 tokens
Comprimento	Número de tokens visíveis da função	Teto de 2.048 tokens

- Três receitas 3B, cada uma com uma semente.
- Uma receita 7B, com sementes 1, 2 e 3.
- NVIDIA A40 48 GB, PyTorch e Transformers com versões registradas.

Receitas e logs oficiais. Prompting e classificação diferem também em variante e contexto.

Receitas de treino e seleção de época

Receita	Vulneráveis	Não vulneráveis	Épocas
3B 1:1 sorteado	5.574	5.574	3
3B proporção original	5.574	178.853	1
3B 1:1 com controle de tamanho	5.574	5.574	3
7B com controle de tamanho	5.574	5.574	3 por semente

- Controle de tamanho: selecionar não vulneráveis de comprimento próximo, sem reposição.
- Escolha histórica da época: ordenação estrita nos pares de validação, com AUC como desempate.

A revisão com meio crédito para empates manteve as épocas nos quatro treinos com controle de tamanho. As receitas tiveram volumes e durações diferentes.

Receitas de treino e selecao_epocas.json. Pilotos 3B sem controle não registraram empates por época.

Regras de avaliação

Decisões por limiar

Regra: escore $s > t$.

- Limiar de maior F1 na validação.
- Outro limiar com FPR de até 0,5% na validação.

Os mesmos limiares seguem para o teste.

Ordenação pareada

Crédito por par:

- 1 se $s_v > s_c$.
- 0,5 se $s_v = s_c$.
- 0 se $s_v < s_c$.

Referência sem preferência entre versões: 50%.

A ordenação independe do limiar. O ponto local de baixa FPR usa validação e não reproduz o VD-Score oficial.

Método, Seção 3.5. v: vulnerável. c: corrigida. Meio crédito não equivale à fração de pares com ordem estritamente correta.

Referência por prompting

Modelo	F1	Precisão	Revocação	FPR	P-C
3B Instruct	0,119	0,102	0,144	3,49%	16/564
7B Instruct	0,062	0,038	0,160	11,00%	14/564

- O 7B encontrou 111 das 695 vulneráveis, contra 100 do 3B.
- Os alarmes falsos passaram de 879 para 2.774.
- Nos pares, a resposta mais frequente foi declarar ambas as versões não vulneráveis.

O modelo maior teve menor F1 nessa instrução.

Tabela de prompting da consolidação. P-C conta pares com as duas decisões corretas. Uma instrução sem exemplos, com decodificação gulosa.

A heurística de comprimento

Referência sem aprendizado

Escore igual ao número de tokens visíveis, com teto de 2.048.

Teste global	Teste pareado
F1: **0,200**	Ordenação: **21,10%**
AUC ROC: **0,810**	P-C: **2 de 564 pares**

Funções vulneráveis tendem a ser mais longas no conjunto global.

Nos pares sem empate, a versão corrigida tem mais tokens visíveis com maior frequência que a vulnerável.

Heurística de comprimento, tabelas globais e pareadas. F1 e P-C usam limiar calibrado na validação.

Desempenho global e ordenação pareada

Configuração	F1	AUC ROC	Ordenação
Comprimento	0,200	0,810	21,10%
3B 1:1 sorteado	0,195	0,795	42,38%
3B proporção original	**0,262**	**0,851**	37,50%
3B com controle de tamanho	0,121	0,746	49,20%
7B NF4, média de três sementes	0,128	0,743	50,62%

O maior F1 global coexistiu com ordenação pareada abaixo de 50%.

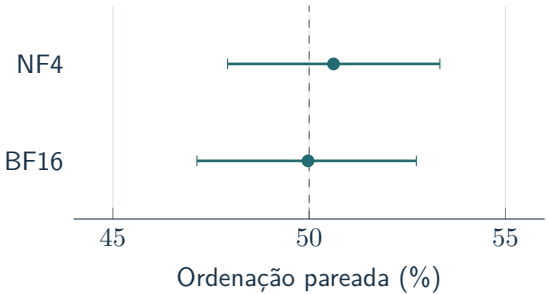
O padrão é compatível com uso de características correlacionadas ao rótulo. O desenho não isola a causa das diferenças entre receitas.

Tabelas consolidadas. F1 usa limiar de maior F1 na validação. Teste global: 25.911 funções. Pareado: 564 pares, com meio crédito para empates.

Variação entre sementes do 7B

Semente	NF4	BF16
1	55,23%	53,28%
2	45,04%	44,68%
3	51,60%	51,95%
Média	50,62%	49,97%

Diferença média: 0,65 p.p.
IC95%: $[-1{,}22;\ 2{,}54]$ p.p.



Intervalos por bootstrap de 550 grupos projeto/commit, condicionais aos três modelos observados. Incluem diferenças em ambas as direções.

Tabela 6 da consolidação. 10.000 réplicas alinhadas. Os intervalos não estabelecem equivalência nem descrevem futuros treinamentos.

Memória e tempo de implantação

Recurso do 7B	NF4 + adaptador	BF16 mesclado
Memória após carga	4,63 GB	14,15 GB
Pico registrado	12,49 GB	20,76 GB
Tempo por função	59,6–60,0 ms	46,8–47,1 ms

- NF4 usou cerca de 67% menos memória após a carga.
- BF16 teve menor tempo amortizado por função.

A comparação muda representação da base e mesclagem do adaptador ao mesmo tempo.

A40, Transformers, contexto de 2.048 e lotes de até 32.768 tokens. GB decimais de memória CUDA alocada. Tempo em lotes, não latência individual. Pico na pontuação de dev/teste/pares.

Operação com poucos falsos positivos

Limiar escolhido para FPR de até 0,5% na validação e aplicado ao teste.

Configuração	FNR no teste	FPR no teste
3B proporção original	88,06%	0,65%
3B com controle de tamanho	96,26%	0,63%
7B NF4, semente 1	97,99%	0,69%
7B NF4, semente 2	98,71%	0,38%
7B NF4, semente 3	98,27%	0,56%

A restrição reduziu alarmes, mas deixou passar a maior parte das vulnerabilidades.

FNR: proporção de vulneráveis perdidas. FPR: proporção de não vulneráveis com alarme falso. O teto da validação não garante o mesmo teto no teste.

Truncamento e correspondência dos pares

Recorte de teste	Pares
Referência oficial	564
Sem truncamento nas duas versões	465
Sem cinco correspondências inadequadas	559
Interseção dos dois controles	460

- O corte em 2.048 tokens torna idênticas as entradas de 32 pares.
- A inspeção focalizada confirmou cinco pares com funções diferentes.
- Remover esses cinco casos mudou o 7B em até 0,22 p.p.

Auditoria e sensibilidades da consolidação. Os 564 pares permanecem na análise principal. A inspeção não certifica os demais pares.

Limites da interpretação

- Análise retrospectiva e exploratória, com consulta prévia ao teste durante o desenvolvimento.
- Receitas com volumes, épocas e custos diferentes. Comparação descritiva entre 3B e 7B.
- Uma semente por receita 3B e três no 7B. Dependência entre exemplos e grupos ainda possível.
- Uma família de modelos, um dataset e um ambiente de inferência. Escores históricos com cinco casas decimais.

Limitações do manuscrito atual. Ordenação perto de 50% não demonstra ausência de compreensão. Deduplicação não prova ausência de contaminação no pré-treinamento.

Estado atual e continuidade

Entregas disponíveis

Resultados consolidados, scripts de reconstrução, manuscrito completo e suplemento com rastreabilidade.

Próximo desenho experimental

- Receitas e critérios definidos antes de um novo teste.
- Mais sementes e orçamento de treino comparável.
- BF16 com adaptador separado e medições repetidas.

No plano amplo: AWQ/GPTQ/INT8, outros modelos, energia e robustez ainda dependem de priorização.

Conclusão e README do artigo. Autoria/afiliação e regras de extensão ainda precisam de fechamento editorial.

Pontos para discutir na orientação

O achado mais consistente é a diferença entre desempenho global e discriminação dos pares.

1. Qual peso dar à avaliação pareada e à eficiência na pergunta central do mestrado?
2. Qual comparação confirmatória deve vir primeiro?
3. A comparação de quantização precisa de um baseline especializado adicional, como UniXcoder?
4. Qual escopo é adequado para a qualificação e para o primeiro artigo?

Apoio: categorias pareadas e empates

Categoria	Versão vulnerável	Versão corrigida	Leitura
P-C	Vulnerável	Não vulnerável	Ambas corretas
P-V	Vulnerável	Vulnerável	Alarme nas duas
P-B	Não vulnerável	Não vulnerável	Nenhum alarme
P-R	Não vulnerável	Vulnerável	Decisões invertidas

$$A_{\text{par}} = \frac{1}{N}\sum_{j=1}^{N}\left[\mathbf{1}(s_{v,j} > s_{c,j}) + \frac{1}{2}\mathbf{1}(s_{v,j} = s_{c,j})\right]$$

Categorias dependem do limiar. Ordenação com meio crédito não equivale a P-C.

Método do manuscrito. A referência de 25% para P-C só vale para palpites independentes e equilibrados entre as duas respostas.

Apoio: hiperparâmetros e ambiente

Componente	Configuração registrada
Adaptação	LoRA $r = 16$, $\alpha = 32$, dropout 0,05 e cabeça treinável
Módulos	q, k, v, o, gate, up, down
Base e cálculo	NF4, dupla quantização e computação BF16
Otimização	AdamW convencional, taxa 2×10^{-4}, warmup 3%
Lote e perda	16 funções efetivas, entropia cruzada sem peso de classe
Ambiente	PyTorch 2.8.0+cu128, Transformers 5.17.0
Adaptação/quantização	PEFT 0.21.0 e bitsandbytes 0.50.2

Receitas oficiais e suplemento S5/S11. Contexto: 2.048 tokens. Checkpointing de gradientes, norma máxima 1,0, sem decaimento de pesos e scheduler linear.

Apoio: sensibilidade da ordenação

Configuração	564 pares	559 pares	460 pares
Comprimento	21,10%	20,57%	14,46%
3B proporção original	37,50%	37,30%	33,80%
3B com controle de tamanho	49,20%	49,02%	48,48%
7B NF4, semente 1	55,23%	55,19%	54,02%
7B NF4, semente 2	45,04%	45,26%	42,61%
7B NF4, semente 3	51,60%	51,52%	51,52%

559: remoção das cinco correspondências inadequadas. 460: mesmo recorte, também sem truncamento.

Tabela suplementar de sensibilidade. Recortes retrospectivos alteram a composição da amostra e não certificam os rótulos restantes.

Apoio: referências e material do projeto

- Ding et al. (2024). *Vulnerability Detection with Code Language Models: How Far Are We?* arXiv:2403.18624.
- Risse e Böhme (2024). *Uncovering the Limits of Machine Learning for Automatic Vulnerability Detection*. USENIX Security.
- Hu et al. (2021). *LoRA: Low-Rank Adaptation of Large Language Models*. arXiv:2106.09685.
- Dettmers et al. (2023). *QLoRA: Efficient Finetuning of Quantized LLMs*. arXiv:2305.14314.
- Hui et al. (2024). *Qwen2.5-Coder Technical Report*. arXiv:2409.12186.
- Huang et al. (2026). *Do Fine-Tuned LLMs Understand Vulnerabilities? An Investigation into the Semantic Trap*. arXiv:2601.22655.

Fontes dos números: consolidação de 08/10/2026, manuscrito atual e suplemento, em `03_experimentos/resultados/` e `04_escrita/artigo/seminarios_2026/`.